

Alexander Ticket

Note: This report has been sanitized for public sharing.

All internal IPs, hostnames, and Splunk URLs have been redacted or replaced with simulated values.

Report was originally prepared for Jira; internal console links are not publicly accessible. Query references shown for context

QRadar ID: 56255

Description

Suricata triggered "ET WEB_SERVER Script tag in URI, Possible Cross Site Scripting Attempt" (SID: 2009714) from 178.244.199.117 to [internal web server] over HTTP port 80. The GET requests targeted the /search.php script via the "searchdata" parameter, injecting malicious JavaScript payloads (<script> tags) to verify reflected input and attempt session cookie (document.cookie) exfiltration.

Victim:

[internal web server] - redacted-domain.local

* I Encoded log:*

```
"/search.php?searchdata=%3Cscript%3Ealert%28%27XSS_Probe_Verified_ID_9921%27%29%3C%2Fscript%3E&search="
```

* I Decoded log:*

```
"/search.php?searchdata=**<script>alert('XSS_Probe_Verified_ID_9921')</script>**&search="
```

** 2 Encoded log:**

```
"/search.php?searchdata=%3Cscript%3Ealert%28%27document.cookie%27%29%3C%2Fscript%3E&search="
```

** 2 Decoded log:**

```
"/search.php?searchdata=**<script>alert('document.cookie')</script>**&search="
```

** 3 Encoded log:**

```
"/search.php?searchdata=%3Cscript%3Ealert%28document.cookie%29%3C%2Fscript%3E&search="
```

** 3 Decoded log:**

```
"/search.php?searchdata=**<script>alert(document.cookie)</script>**&search="
```

ATTACKER INFO:

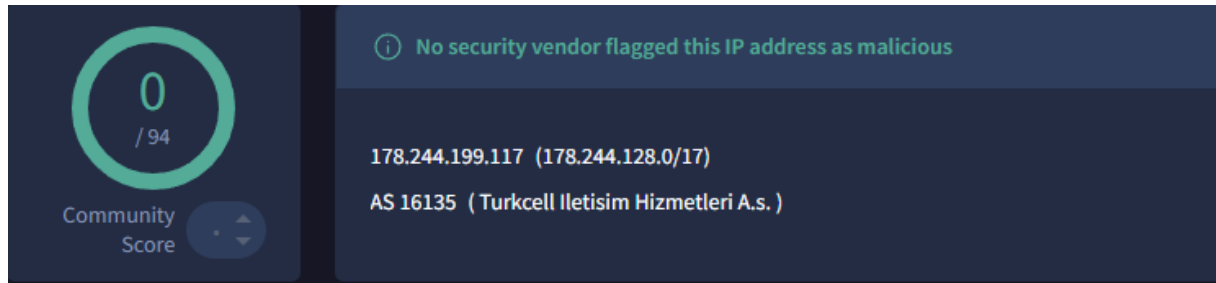
IP: 178.244.199.117 on port 4943 , 6252, 5706

User Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 - this string identifies a standard Google Chrome browser operating on Windows 10. Unlike automated bot headers, this suggests manual probing or the use of stealth-oriented scanning tools attempting to mimic legitimate user activity. As User-Agent headers are easily spoofed, this activity should be correlated with the observed XSS payloads and source IP reputation to confirm malicious intent.

ANALYST INVESTIGATION:

Virus Total: **[Result here]**<https://www.virustotal.com/gui/ip-address/178.244.199.117>

Security Vendors' Analysis from Virus Total: **0/94 security vendors flagged this IP address as malicious**



Talos Intelligence:

REPUTATION DETAILS:

Email Reputation: *Neutral*

Web Reputation: *Neutral*

Talos Result:

[Result here]https://talosintelligence.com/reputation_center/lookup?search=178.244.199.117

LOCATION DATA

NO LOCATION DATA AVAILABLE.

OWNER DETAILS

IP ADDRESS	178.244.199.117
FWD/REV DNS MATCH	No data
HOSTNAME	-
DOMAIN	-
NETWORK OWNER	TURKCELL

CONTENT DETAILS

CONTENT CATEGORY No established content categories

Think these category details are incorrect?

Submit Content Categorization Ticket

REPUTATION DETAILS

SENDER IP REPUTATION Neutral [Submit Sender IP Reputation Ticket](#)

WEB REPUTATION Neutral [Submit Web Reputation Ticket](#)

EMAIL VOLUME DATA

	LAST DAY	LAST MONTH
EMAIL VOLUME	0.0	0.0
VOLUME CHANGE	0%	

BLOCK LISTS

BL.SPAMCOP.NET	Not Listed
CBL.ABUSEAT.ORG	Not Listed
PBL.SPAMHAUS.ORG	Not Listed
SBL.SPAMHAUS.ORG	Not Listed

TALOS SECURITY INTELLIGENCE BLOCK LIST

ADDED TO THE BLOCK LIST	No
-------------------------	----

Shodan: No results found

[Result here] <https://www.shodan.io/search?query=178.244.199.117>

45.64.74.56

[Regular View](#)
[Raw Data](#)
[Timeline](#)
[Whois](#)

General Information

Country

Hong Kong

City

Hong Kong

Organization

Cloudie Limited

ISP

Cloudie Limited

ASN

AS55933

Web Technologies

Reverse Proxies

Nginx

Web Servers

Nginx

Open Ports

80

888

// 80 / TCP

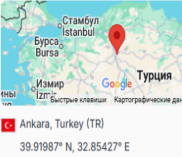
nginx

没有找到站点

HTTP/1.1 200 OK
 Server: nginx
 Date: Wed, 18 Mar 2020 06:05:05 GMT
 Content-Type: text/html
 Content-Length: 1326
 Last-Modified: Wed, 18 Mar 2020 06:05:05 GMT
 Connection: keep-alive
 Vary: Accept-Encoding
 ETag: "59005463-52e"
 Accept-Ranges: bytes

// 888 / TCP

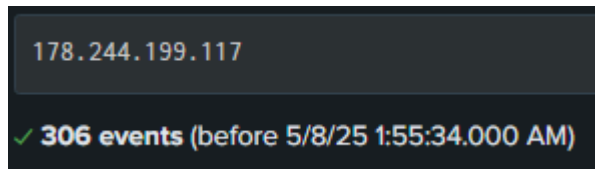
CensysResult: **[Result: https://platform.censys.io/hosts/178.244.199.117]**

178.244.199.117 * HOST		Summ	
/		Network and Geolocation	
No Data	WHOIS Network	TURKCELL INTERNET	
No Data	WHOIS Organization	TR-TURKCELL-INTERNET	
No Data	WHOIS Organization	Turkcell İletişim Hizmetleri A.Ş.	
65	Autonomous System	Aydınevler Mah. İnönü Cad. No:20 Kucukyalı Ofispark Maltepe, 34854, İSTANBUL, TURKEY	
		ORG-TIHAT-RIPE	
		178.244.192.0/20	
		TURKCELL-AS Turkcell A.S. (16135), TR	

Splunk Investigation: A comprehensive search for source IP **178.244.199.117** across all indexes identified **306 total events** targeting `redacted-domain.local`. The investigation revealed a multi-stage attack pattern involving prolonged reconnaissance followed by a high-intensity exploitation burst.

Result 1: Splunk search - internal link (not accessible)

↓↓↓



Early Reconnaissance (05:52 AM): Initial activity was detected hours before the main alert. A single probe at 05:52 AM indicates "low and slow" scanning, likely to identify active parameters without triggering threshold-based alarms.

Exploitation Burst Qradar detection (14:42 – 14:47 PM): The core of the attack consisted of a rapid sequence of requests (300+ events) within a 5-minute window, shifting from generic fuzzing to targeted XSS injections.

Result 2: Splunk search - internal link (not accessible)

↓↓↓

2025-03-31 05:52:00
2025-03-31 05:53:00
2025-03-31 05:54:00
2025-03-31 05:55:00
2025-03-31 05:56:00
2025-03-31 05:57:00
2025-03-31 05:58:00
2025-03-31 05:59:00
2025-03-31 06:00:00
2025-03-31 06:01:00
2025-03-31 06:02:00
2025-03-31 06:03:00
2025-03-31 06:04:00
2025-03-31 06:05:00
2025-03-31 06:06:00
2025-03-31 06:07:00
2025-03-31 06:08:00
2025-03-31 06:09:00
2025-03-31 06:10:00
2025-03-31 06:11:00

WAF Detection (ModSecurity): The `apache_error` logs confirmed that the Web Application Firewall (WAF) triggered **CRITICAL** anomalies. Specifically, **Rule ID 941160** (NoScript XSS InjectionChecker) and **Rule ID 980130** (Inbound Anomaly Score Exceeded) were triggered.

IDS Correlation (Suricata): These WAF events directly correlate with Suricata **SID 2009714**, confirming a multi-vector detection of the same malicious payloads.

Critical Finding (Status 200): Despite the **CRITICAL** severity score from ModSecurity, the web server consistently responded with **HTTP 200 (OK)**. This confirms the WAF is currently in **"Detection Only"** mode, allowing the malicious scripts to be reflected in the application response.

Result 3: Splunk search - internal link (not accessible)

* 1 Raw Data:*

```
{ "timestamp": "2025-03-31T14:42:30.718739-0400", "flow_id": 227706643310457, "in_iface": "eth0", "event_type": "alert", "src_ip": "178.244.199.117", "src_port": 4943, "dest_ip": "[internal web server]", "dest_port": 80, "proto": "TCP", "tx_id": 0, "alert": { "action": "allowed", "gid": 1, "signature_id": 2009714, "rev": 5, "signature": "ET WEB_SERVER Script tag in URI, Possible Cross Site Scripting Attempt", "category": "Web Application Attack", "severity": 1 }, "http": { "hostname": "redacted-domain.local", "url": "\search.php?searchdata=%3Cscript%3Ealert%28%27XSS_Probe_Verified_ID_9921%27%29%3C%2Fscript%3E&search=", "http_user_agent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36", "http_content_type": "text/html", "http_refer": "http://redacted-domain.local/search.php?searchdata=sean&search=", "http_method": "GET", "protocol": "HTTP/1.1", "status": 200, "length": 1056 } }
```

* 2 Raw Data:*

```
{ "timestamp": "2025-03-31T14:46:05.083026-0400", "flow_id": 873152195122188, "in_iface": "eth0", "event_type": "alert", "src_ip": "178.244.199.117", "src_port": 6252, "dest_ip": "[internal web server]", "dest_port": 80, "proto": "TCP", "tx_id": 0, "alert": { "action": "allowed", "gid": 1, "signature_id": 2009714, "rev": 5, "signature": "ET WEB_SERVER Script tag in URI, Possible Cross Site Scripting Attempt", "category": "Web Application Attack", "severity": 1 }, "http": { "hostname": "redacted-domain.local", "url": "\search.php?searchdata=%3Cscript%3Ealert%28%27document.cookie%27%29%3C%2Fscript%3E&search=", "http_user_agent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36", "http_content_type": "text/html", "http_refer": "http://redacted-domain.local/search.php?searchdata=%3Cscript%3Ealert%28%27XSS_Probe_Verified_ID_9921%27%29%3C%2Fscript%3E&search=", "http_method": "GET", "protocol": "HTTP/1.1", "status": 200, "length": 1056 } }
```

* 3 Raw Data:*

```
{ "timestamp": "2025-03-31T14:47:12.163855-0400", "flow_id": 1639406577333445, "in_iface": "eth0", "event_type": "alert", "src_ip": "178.244.199.117", "src_port": 5706, "dest_ip": "[internal web server]", "dest_port": 80, "proto": "TCP", "tx_id": 0, "alert": { "action": "allowed", "gid": 1, "signature_id": 2009714, "rev": 5, "signature": "ET WEB_SERVER Script tag in URI, Possible Cross Site Scripting Attempt", "category": "Web Application Attack", "severity": 1 }, "http": { "hostname": "redacted-domain.local", "url": "\search.php?searchdata=%3Cscript%3Ealert%28%27document.cookie%27%29%3C%2Fscript%3E&search=", "http_user_agent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36", "http_content_type": "text/html", "http_refer": "http://redacted-domain.local/search.php?searchdata=%3Cscript%3Ealert%28%27document.cookie%27%29%3C%2Fscript%3E&search=", "http_method": "GET", "protocol": "HTTP/1.1", "status": 200, "length": 2476 } }
```

Additional Findings:

178.244.199.117 was not found in our database

ISP	TURKCELL INTERNET
Usage Type	Mobile ISP
ASN	Unknown
Domain Name	turkcell.com.tr
Country	 Turkey
City	Ankara, Ankara

IP info including ISP, Usage Type, and Location provided by [IPInfo](#). Updated biweekly.

[REPORT IP](#)[WHOIS SEARCH](#)

ResultAbuseIPDB: [\[here|https://www.abuseipdb.com/check/178.244.199.117\]](https://www.abuseipdb.com/check/178.244.199.117)

ANALYST ASSESSMENT

Suricata IDS and ModSecurity WAF triggered multiple critical alerts for source IP 178.244.199.117 targeting [internal web server] (redacted-domain.local). Splunk investigation identified a persistent, multi-stage campaign consisting of 306 total events. The attack evolved from early-morning WAF bypass attempts and SQL injection probing (05:52 AM) to high-intensity XSS exploitation in the afternoon (14:47 PM).

Despite CRITICAL anomaly scores from the WAF, all requests resulted in HTTP 200 (OK), confirming the security stack is in "Detection Only" mode and the application is vulnerable to script reflection.

- **Attack Details**

Source → Destination: 178.244.199.117 (src ports 4943, 6252, 5706) → [internal web server] (redacted-domain.local)

Targeted Parameter: **searchdata** within **/search.php** and root directory **/index.php**.

Events Funnel: 306 total events → 1 early stealth probe (05:52 AM) → 300+ afternoon fuzzing events → 3 critical XSS alerts → Potential Success (Status 200).

HTTP Method / Status: GET — observed responses HTTP 200 (OK), confirming the server processed and reflected malicious payloads.

Signatures Triggered: * Suricata: **ET WEB_SERVER Script tag in URI**, **Possible Cross Site Scripting Attempt** (SID: 2009714).

- **ModSecurity:** **Rule 941160 (NoScript XSS InjectionChecker)** & **Rule 980130 (Inbound Anomaly Score Exceeded)**.

1. Early WAF Bypass Attempt (05:52 AM): The investigation of **modsec_audit** logs revealed a sophisticated attempt to overwhelm the WAF. The attacker used oversized or highly complex payloads that triggered "PCRE limits exceeded (-8)" errors. This is a known technique to bypass Regular Expression-based filters; when the engine hits its processing limit, it may "fail open," allowing the malicious string to reach the backend **index.php** unsanitized.

2. XSS Payload Progression (14:42 – 14:47 PM): Analysis of the **http_refer** and URL strings shows a clear shift from automated fuzzing to manual verification:

- **Initial PoC:**
<script>alert('XSS_Probe_Verified_ID_9921')</script> — used to confirm the application reflects input.

- **Exploitation:** `<script>alert(document.cookie)</script>` — a direct attempt to access sensitive session tokens.

3. Stealth Indicators: The use of a standard Chrome 146 / Windows 10 User-Agent and a "Neutral" reputation IP (0/94 on VirusTotal) suggests either a fresh infrastructure or a highly targeted manual engagement designed to bypass simple reputation-based blocks.

Impact if Successful

Session Hijacking: The successful execution of `document.cookie` payloads allows the attacker to steal session identifiers, leading to full account takeover of any user (including admins) who clicks the malicious link.

Data Exfiltration: Early morning triggers for `RESPONSE-951-DATA-LEAKAGES-SQL` suggest the attacker is also actively seeking database vulnerabilities to leak customer or system data.

Phishing & Defacement: Reflected XSS can be used to inject fake login forms or redirect users to malicious domains, severely damaging the organization's reputation.

Mini Attack Visualization:

[Attacker IP 178.244.199.117 begins stealth reconnaissance on target — [internal web server] (redacted-domain.local)]



[05:52 AM: Reconnaissance phase targeting index.php with complex SQLi payloads]



[WAF Evasion: "PCRE limits exceeded (-8)" error indicates attempt to bypass regex filters via payload complexity]



[14:42 PM: Shift to /search.php using automated XSS fuzzing (Chrome 146 User-Agent)]



[Payload example 1 :

`<script>alert('XSS_Probe_Verified_ID_9921')</script>` — *Intent: Verify input reflection*



[Payload example 2 :

`<script>alert(document.cookie)</script>` — *Intent: Session token theft*



[Detection: Suricata SID 2009714 & ModSecurity Critical Anomaly Rules 941160, 980130 triggered]



[HTTP 200 OK — WAF in "Detection Only" mode, malicious payload successfully reflected]



[Conclusion: Multi-stage campaign confirmed. High risk of Session Hijacking and Account Takeover]

Recommended Actions

Block and Contain:

- **Immediate Block:** Blacklist the source IP 178.244.199.117 at the perimeter firewall and WAF levels.
- **Subnet Watch:** Monitor the 178.244.199.0/24 subnet for coordinated activity, as the morning SQLi and afternoon XSS phases suggest a persistent actor.
- **Session Management:** Revoke all active sessions for users who accessed `/search.php` during the attack window (14:40 – 14:50 PM) to prevent potential Session Hijacking via the leaked `document.cookie`.

Preserve Evidence:

- **Log Archival:** Collect and archive all ModSecurity audit logs (including the PCRE limit exceeded errors), Suricata alerts (SID 2009714), and Apache access logs for forensic retention and internal RCA (Root Cause Analysis).

Investigate Impact:

- **Payload Reflection Audit:** Perform a manual review of the application's response to ensure the `<script>` tags were indeed rendered in the browser (Status 200 verification).
- **Database Integrity Check:** Audit database logs from 05:52 AM to ensure the SQLi probes targeting `index.php` did not result in unauthorized data exfiltration or table modification.
- **Account Monitoring:** Review logs for any administrative logins or unusual account changes following the XSS burst, as stolen cookies could lead to unauthorized privilege escalation.

WAF & Server Hardening:

- **Enforcement Mode:** Transition ModSecurity from "Detection Only" to "Blocking" mode for the OWASP Core Rule Set (specifically rules 941160 and 980130).
- **PCRE Optimization:** Increase the `SecPcreMatchLimit` and `SecPcreMatchLimitRecursion` in the WAF configuration to prevent future bypasses via oversized or complex payloads.

System Security:

- **Input Sanitization:** Implement server-side HTML Entity Encoding on the `searchdata` parameter to ensure all user input is rendered as text, not executable script.
- **Cookie Hardening:** Enforce the `HttpOnly` and `Secure` flags for all session identifiers. The `HttpOnly` flag is critical to prevent JavaScript from accessing cookies during an XSS attack.

Monitoring & Follow-up:

- **Targeted Alerting:** Create a custom SIEM alert for any "Status 200" responses involving the string `<script>` or `document.cookie` on the `redacted-domain.local` host.
- **Escalation:** If any evidence of session takeover or successful SQLi data leakage is identified, escalate to the Incident Response (IR) Team for full host isolation and password reset procedures across the domain.